

APSEA: An Awareness and Prevention Expert System against Social Engineering Attacks in Public Organizations

Waldson Rodrigues Cardoso (✉ waldson.cardoso@dcomp.ufs.br)

Universidade Federal de Sergipe

Admilson de Ribamar Lima Ribeiro

Universidade Federal de Sergipe

João Marco Cardoso Silva

University of Minho

Research Article

Keywords: Social Engineering Attacks , Information Security , Expert System , Awareness , Mitigation

Posted Date: February 16th, 2024

DOI: <https://doi.org/10.21203/rs.3.rs-3925659/v1>

License:   This work is licensed under a Creative Commons Attribution 4.0 International License.

[Read Full License](#)

Additional Declarations: No competing interests reported.

APSEA: An Awareness and Prevention Expert System against Social Engineering Attacks in Public Organizations

Waldson Rodrigues Cardoso^{a,1}, Admilson de Ribamar Lima Ribeiro^{b,2},
João Marco Cardoso Silva^{c,3}

¹waldson.cardoso@dcomp.ufs.br, Computing Department, Federal University of Sergipe, UFS São Cristóvão, Brazil

²admilson@dcomp.ufs.br, Computing Department, Federal University of Sergipe, UFS São Cristóvão, Brazil,

³joaomarco@di.uminho.pt Department of Informatics, University of Minho Braga, Portugal,

Received: date / Accepted: date

Abstract The growing concern for information security arises from the risks associated with the dissemination of personal data on the internet and the increasing incidents of social engineering attacks, which exploit psychological vulnerabilities. These attacks pose a substantial threat to individuals and organizations, potentially resulting in significant financial losses. This article highlights the development of the APSEA tool - Awareness and Prevention Expert System against Engineering Attacks, an expert system designed to raise awareness and prevent social engineering attacks in public organizations. The tool aims to make employees vigilant against such threats, empowering them to identify and avoid psychological manipulation techniques used by attackers. Despite existing protective measures such as awareness training and security policies, APSEA seeks to contribute to strengthening the human factor in information security. The article covers key concepts in information security, presenting interactive modules and artificial intelligence features to identify vulnerabilities. A qualitative and performance evaluation of the tool is conducted, and the results indicate that the adopted approach is effective in achieving its objectives.

Keywords Social Engineering Attacks · Information Security · Expert System · Awareness · Mitigation

1 Introduction

The growing significance of digital information brings both opportunities and security challenges. The ubiquity of social networking platforms allows attackers to

collect employees' data through their online activities, potentially facilitating attacks on organizations. Given the crucial role of human decision-making in information security, even robust technical safeguards become ineffective if attackers successfully influence employees [1].

Social Engineering, a technique using tactics like persuasion, intimidation, coercion, extortion, or blackmail, is employed to extract information. Social engineers study human behavior, personality traits, and body language to manipulate or deceive victims, making it a prominent cyber-attack technique. Despite technological advancements, human error remains a significant factor in the success of social engineering attacks [2].

This article introduces the APSEA (Awareness and Prevention Expert System against Engineering Attacks), an expert system as a tool designed to raise awareness and prevent social engineering attacks. The purpose of the developed tool is to empower employees to recognize and prevent psychological manipulation techniques employed by attackers. The central aim is to strengthen the role of the human factor in information security, making them more vigilant against these threats.

The article's structure is organized into several sections to provide a comprehensive understanding of the content. In Section 2, we will address the context and background. Section 3 will revisit related works to contextualize the article's contribution. Section 4 details the project of the APSEA tool, presenting its main modules and functionalities. Implementation is discussed in Section 5, followed by a qualitative and performance assessment in Section 6. Section 7 will host a results. Finally, in Section 8, we will present our conclusions, summarizing the main points and contributions of this study.

^ae-mail: waldson.cardoso@dcomp.ufs.br

^be-mail: admilson@dcomp.ufs.br

^ce-mail: joaomarco@di.uminho.pt

2 Background

Some of the basic concepts that are necessary to read this article are briefly introduced in this section.

2.1 Social engineering and expert systems

In this section, we will provide an overview of the key concepts related to social engineering and discuss the importance of awareness and mitigation measures against these attacks. We will discuss the types of social engineering attacks, the mitigating social engineering attacks and expert systems.

2.2 Types of Social Engineering Attacks

Social engineering encompasses a wide variety of techniques used by attackers to psychologically manipulate individuals and gain access to confidential information. The main techniques include phishing, quid pro quo, pretexting, baiting, and tailgating. Each technique is based on either software or human actions and focuses on one or more principles of social engineering. These principles include authority, intimidation, urgency, scarcity, and familiarity. By leveraging psychology and these principles, attackers can convince or deceive victims into clicking on a virus-infected link, inserting an infected USB into a computer, or exploiting common courtesy against them [2].

There are different types of social engineering attacks, which can be categorized into physical, social, technical, and sociotechnical approaches [3].

1. Physical approaches involve physical actions by the attackers, such as dumpster diving, theft, or extortion.
2. Social approaches are based on sociopsychological techniques, such as the use of authority, curiosity, and the creation of relationships with the victims.
3. Technical attacks are primarily conducted through the Internet, taking advantage of people's lack of awareness regarding the disclosure of personal information and the use of weak passwords.
4. Sociotechnical approaches combine different techniques to create powerful attacks

Social engineering attacks occur across various channels and can be carried out by both humans and software. It is important to note that the boundaries of these attack types are flexible and constantly evolving. Understanding these techniques and their mechanisms is essential for developing effective awareness and prevention strategies.

2.3 Mitigating Social Engineering Attacks

Strategies for dealing with social engineering attacks can be classified into prevention, detection, and mitigation [4]. Under prevention, there are two categories: human user prevention systems and technological prevention systems. Human user prevention systems involve the implementation of policies and processes within the organization, as well as cybersecurity awareness programs and training. Technological prevention systems include website scanning and research, the use of browser extensions like TabShots, and the implementation of a blacklist for malicious traffic.

Detection strategies can be divided into human detection techniques and technological detection techniques. Human detection techniques involve using humans as security sensors, dynamic security covers, and social engineering-centered risk assessment. Technological detection techniques include detecting visually similar phishing web pages using earthmover distance and protection against forgeries.

As for mitigation strategies, they encompass cyber fraud, detection of fake social media accounts, social media awareness, Trojan horse countermeasures, security awareness applied to individuals and organizations, and countermeasures against device-based banking fraud.

Therefore, strategies for dealing with social engineering attacks involve a combination of preventive measures, detection techniques, and mitigation actions.

2.4 Expert Systems

Expert systems were expected to appear in the late 20th century, as private research into the creation and application of artificial intelligence [5].

According to [6], Expert system (ES) is a branch of Artificial Intelligence that makes extensive use of expert knowledge to solve problems at the level of the human expert in a specific domain. For [7], the expert system can be considered as a descriptive programming language because programmers do not need to specify how to perform the specific algorithm. Now, there are various types of expert systems, such as frameworks based expert systems, thought-based expert systems, and rule-based expert systems, and so on.

According to [8], knowledge must be presented in an understandable format to perform any kind of reasoning in the expert system, which is known as knowledge representation. The expert system consists of two components: knowledge base and logical reasoning. The knowledge base is the first component of an expert system and is a collection of information that is in a well-defined representation. The second component of an ex-

pert system is the logical reasoner that performs all the necessary thinking on a previously constructed knowledge base. With this logical reasoner we conclude new information from the previously built knowledge base. Several methods have been adopted in the construction of expert systems in different domains, such as Forward Chaining, Backward Chaining, Fuzzy and the Certainty Method [6].

These methods for constructing expert systems are selected based on the nature of the domain and the characteristics of the specific problem. Each method has its own advantages and limitations, and the appropriate choice depends on the specific application. Moreover, the development of expert systems requires collaboration between domain experts and computer science professionals to ensure an accurate and effective representation of knowledge in the system. These approaches and collaborations contribute to the creation of robust and reliable expert systems in various contexts.

The next section presents a review of relevant studies related to social engineering in organizations. These studies address the threats and trends of social engineering, mitigation strategies, educational tools, and models to increase awareness and resistance against social engineering attacks.

3 Related works

A study conducted by researchers identified social engineering as one of the most dangerous threats in the current context, due to its potential for stealing confidential information and its negative consequences for organizations [9]. Another research proposed detailed models of social engineering attacks, mapping real-world examples to an attack framework [9]. Additionally, a study introduced a multi-stage analysis approach to social engineering attacks, considering the attacker's accidental factors [10].

Several studies have also explored educational strategies and tools to increase awareness and resistance against social engineering. One work proposed an information technology governance framework applied in a bank, with a focus on phishing attack prevention [11]. Another study developed an immersive virtual reality educational game, called "The Social Engineer," to train players in detecting and resisting social engineering attacks [12].

Furthermore, research has explored the role of employee training and awareness in combating social engineering. One study demonstrated how compliance with information security policies can shape employee behavior and mitigate risks [13]. Another work developed

a machine learning-based tool to test employees' resilience against social engineering attacks and promote a culture of information security [14].

In summary, the reviewed studies provide important insights into social engineering in organizations. They address threats, mitigation strategies, educational tools, and models to increase awareness and resistance against social engineering attacks. These findings contribute to the understanding and development of effective information security practices to protect organizations against psychological manipulation and the disclosure of confidential information. Based on these studies, we have identified some gaps in the literature. However, it is important to note that these gaps present an opportunity for further research and technological advancements in this area. Firstly, there is an opportunity to develop interactive and customized awareness tools tailored specifically for public organizations, considering the unique aspects of this environment. Additionally, exploring advanced attack detection techniques that leverage the potential of artificial intelligence and behavior analysis offers a promising direction for future developments. By addressing these opportunities, we can enhance information security measures against social engineering attacks in public organizations.

To address these gaps, an awareness tool against social engineering attacks has been developed in the form of a specialized system specifically tailored for public organizations. The choice to initially focus on public organizations is based on the specific needs of this sector in dealing with the unique challenges and threats it faces. Public organizations often handle a high volume of confidential information and are susceptible to attacks aimed at compromising the security and confidentiality of this data. Furthermore, laws have been enacted to establish essential requirements for organizations to provide support and protection for users' personal data, such as the General Data Protection Regulation (GDPR) and the Brazilian General Data Protection Law (LGPD) [15]. Therefore, it was crucial to develop a tool that takes into account the specifics of this environment, offering tailored solutions and strategies to meet its unique needs. By initially directing our tool towards public organizations, we provide a specialized approach that has been effectively strengthened for awareness and protection against social engineering attacks in this specific context. However, it is important to emphasize that our tool can be adapted and applied to other organizations as needed.

4 APSEA System Design

The goal of the work was to develop and validate an expert system (ES) as an awareness and prevention tool against social engineering attacks targeting users in the context of employees within a public organization. The system aims to educate and instruct on how to avoid social engineering attacks while also providing vulnerability diagnostics for managers. This system has been named APSEA (Awareness and Prevention Expert System against Engineering Attacks).

A basic structure of an Expert System, as depicted in Figure 1, typically consists of a knowledge base (heuristic information, etc.), an inference engine (analyzing the knowledge base), and the end-user interface (accepting inputs, generating outputs).

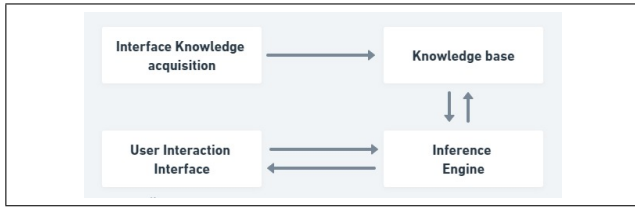


Fig. 1 Basic Structure of the SE

4.1 Knowledge base

The Knowledge Base is a crucial component for Expert Systems, serving as the source of information used by experts [16]. This core element of the system is more than just a data repository; it is a collection of rules designed to solve problems logically and directly. It contains abstract knowledge stored in production rules of the form [If] premise, [Then] conclusion [17].

In the context of APSEA, the construction of the Knowledge Base was carried out meticulously, incorporating practices grounded in the security policies of Department State of Traffic of Sergipe (DETRAN/SE) and references to specialized materials. The base covers a diverse spectrum of social engineering attack types, reflecting potential threats in the DETRAN/SE environment. Close collaboration with security experts and adherence to organizational guidelines ensured the robustness and relevance of the knowledge base.

Implementation was done in the PostgreSQL database, chosen for its widespread use, open-source nature, and effective management capabilities. Production rules were kept simple to facilitate ongoing administration and clear understanding of guidance provided to users. Validation of the knowledge base involved active collabora-

tion with Information Security Analyst, ensuring accuracy and relevance.

Thus, the construction of the Knowledge Base was a joint initiative, integrating theoretical and practical knowledge to create a robust and effective tool for awareness and prevention of social engineering attacks.

4.2 Knowledge representation

In the Knowledge Representation phase, our focus was on developing APSEA to raise awareness among AGIN (General Information and Communication Technology Advisory) users at DETRAN/SE about social engineering attacks and provide educational actions on how to prevent these attacks. This initiative was driven by crucial information from the IT Manager, particularly during the LGPD (General Data Protection Law) adaptation within the organization.

The need arose in line with LGPD guidelines and other specific requirements outlined by the DETRAN/SE. This includes Continuous Vulnerability Management, Security Awareness, Skills Training, and the Acquisition of an Incident Response Management Solution.

Under LGPD, DETRAN/SE requires the establishment and maintenance of awareness and security competency training as an integral part of its guidelines. In this context, APSEA not only meets this requirement but also aligns with the ongoing need to assess and track vulnerabilities, as established in Continuous Vulnerability Management.

Furthermore, DETRAN/SE demands the acquisition of an Incident Response Management Solution to prepare, detect, and respond quickly to attacks. The developed APSEA features functionalities that directly contribute to this demand, enabling a proactive approach to mitigating information security risks.

This flexible and customizable approach, grounded in the specific needs of LGPD and DETRAN/SE guidelines, reflects our commitment to adaptability and effectiveness in raising awareness and preventing social engineering attacks.

4.3 Knowledge acquisition and formation

The Knowledge Acquisition and Formation phase in Expert System (ES) development is vital, involving obtaining and processing data for transformation into applicable models and knowledge. Following best practices, we conducted a careful survey of fundamental information. The goal was to obtain relevant data to construct the APSEA knowledge base effectively. The

process, grounded in DETRAN/SE's security guidelines, prioritized quality, relevance, and specificity in the acquired information. Continuous feedback and validations, in collaboration with security analyst, ensured the accuracy and currency of the information. This iterative approach contributed to building a robust knowledge base tailored to DETRAN/SE's specific needs, enhancing the effectiveness and reliability of the developed APSEA.

4.4 Question Definition

In this phase, questions were precisely formulated to cover various social engineering attack types, potential threats to public organization security. Each question, tailored to the specific nature of an attack, aligns with best practices and organizational realities. These questions assess user understanding of attack scenarios like Phishing, Vishing, Pretexting, Quid Pro Quo, providing targeted educational guidance. This process establishes a robust foundation for user assessment and awareness, significantly enhancing the system's effectiveness in preventing social engineering attacks.

4.5 Rule Definition

In defining rules for APSEA, we adopted a forward-chaining approach, starting with user-provided information to derive specific conclusions. Each rule follows the structure "If [conditions] then [actions]," consisting of conditions (premises) and actions (conclusions). This simplification prioritizes clarity, adaptability, and effectiveness in user feedback, aligning with DETRAN/SE's request for an easily maintainable and comprehensible system.

The straightforward rule structure allows quick adaptation to emerging social engineering threats, ensuring system efficiency. This simplicity caters to DETRAN/SE's specific needs, facilitating smooth knowledge base updates and minimizing the learning curve for administrators. This strategic choice promotes a transparent and accessible system for effective maintenance.

The detailed set of questions and rules formulated during this phase is presented below:

1. **Question 1 (Phishing):** Do you carefully check email senders before opening attachments or clicking on links?

– **Rule 1:**

- **If** Answer = "Always" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Great! Carefully checking senders is crucial to avoid Phishing."

- **Else If** Answer = "Sometimes" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Be vigilant! Improving checking can reduce Phishing risks."

- **Else** Answer = "Never" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Verifying senders is fundamental to avoid Phishing."

2. **Question 2 (Vishing):** Do you distrust unexpected phone calls requesting sensitive information?

– **Rule 2:**

- **If** Answer = "Always" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Great! Distrusting unexpected calls helps avoid Vishing."

- **Else If** Answer = "Sometimes" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Be attentive! Improving distrust can reduce risks of Vishing."

- **Else** Answer = "Never" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Distrusting calls is essential to avoid Vishing."

3. **Question 3 (Pretexting):** Do you verify the legitimacy of requests for personal information, even if they seem official?

– **Rule 3:**

- **If** Answer = "Always" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Excellent! Verifying legitimacy is fundamental to avoid Pretexting."

- **Else If** Answer = "Sometimes" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Be attentive! Improving verification can reduce risks of Pretexting."

- **Else** Answer = "Never" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Verifying legitimacy is essential to avoid Pretexting."

4. **Question 4 (Quid Pro Quo):** Do you refuse offers of benefits in exchange for confidential information, even if they seem advantageous?

– **Rule 4:**

- **If** Answer = "Always" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Congratulations! Refusing offers in exchange for information is essential to avoid Quid Pro Quo."

- **Else If** Answer = "Sometimes" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Be attentive! Refusing suspicious offers can reduce risks of Quid Pro Quo."

- **Else** Answer = "Never" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Refusing suspicious offers is crucial to avoid Quid Pro Quo."

5. **Question 5 (Baiting):** When encountering USB devices or media intentionally left behind, how do you react?

– **Rule 5:**

- **If** Answer = "Connect to the computer" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Connecting unknown devices can expose your system to Baiting risks."
- **Else** Answer = "Ignore" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Attention! Ignoring unknown media is a first step, but assessing the risk is crucial."

6. **Question 6 (Tailgating):** Do you allow unknown individuals to enter restricted areas without checking their credentials?

– **Rule 6:**

- **If** Answer = "Allow entry" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Allowing access without checking credentials can result in Tailgating vulnerabilities."
- **Else** Answer = "Check credentials" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Good job! Checking credentials helps prevent Tailgating situations."

7. **Question 7 (Dumpster Diving):** When disposing of documents or devices, do you take precautions to avoid Dumpster Diving, such as secure destruction of sensitive information?

– **Rule 7:**

- **If** Answer = "Dispose without precautions" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Disposing of information without precautions can result in Dumpster Diving risks. Adopt secure disposal practices."
- **Else** Answer = "Adopt destruction precautions" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Great! Adopting precautions in destroying information helps protect against Dumpster Diving attacks."

8. **Question 8 (Shoulder Surfing):** When entering confidential information on your device, do you take measures to protect against Shoulder Surfing, such as adjusting your position to avoid prying eyes?

– **Rule 8:**

- **If** Answer = "Do not take precautions" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Not taking precautions against Shoulder Surfing can expose sensitive information. Protect your privacy by adopting preventive measures."
- **Else** Answer = "Adopt protection measures" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Congratulations! Adopting measures to

protect against Shoulder Surfing is essential to ensure the security of your confidential information."

9. **Question 9 (Scareware):** When encountering alarming pop-ups or messages on your device, do you stay calm and verify authenticity, avoiding impulsive actions?

– **Rule 9:**

- **If** Answer = "React impulsively" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Impulsive reactions to alarming messages can expose you to Scareware. Stay calm and verify authenticity before taking action."
- **Else** Answer = "Verify authenticity" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Great! Verifying authenticity in the face of alarming messages is a safe practice to avoid Scareware. Continue to stay calm and act with caution."

10. **Question 10 (Phishing):** Faced with an unexpected email offer, how do you decide whether to share your information or not?

– **Rule 10:**

- **If** Answer = "Share" $\Rightarrow$ Vulnerability Level = "High", Feedback = "Caution! Sharing information without evaluation can be risky."
- **Else If** Answer = "Ask for more information" $\Rightarrow$ Vulnerability Level = "Medium", Feedback = "Good approach! Asking for more information helps make informed decisions."
- **Else** Answer = "Decline immediately" $\Rightarrow$ Vulnerability Level = "Low", Feedback = "Great! Declining unexpected offers is a safe practice."

4.6 Inference Engine

The inference mechanism, crucial in handling knowledge, employs heuristic rules to determine which rules will be satisfied, prioritizing the most relevant ones. It can adopt forward or backward chaining in the knowledge base. We chose forward chaining in APSEA, starting with user-provided information and applying rules for specific conclusions. This allows for efficient progression, dynamically adapting to user responses, and providing personalized feedback. This approach aims for simplicity, adaptability, and effectiveness, reflecting the concern to make the system accessible and efficient in raising awareness against social engineering attacks.

4.7 User Interaction Interface

The User Interaction Interface (UI) serves as a crucial communication channel between the Expert System (ES) and users, facilitating information exchange. It captures user responses to fundamental questions, recording them in predefined variables. The UI is vital for collecting user information and displaying ES responses. We implemented the UI using the Laravel framework, a PHP web application framework, and the PHP programming language, ensuring a robust and efficient development process. Blade, Laravel's template engine, was employed for creating intuitive and expressive views. These technological choices aim to deliver both effective technical implementation and a user-friendly interface, contributing to the success of user APSEA interaction.

4.8 System Modeling

Use cases depict individual interactions between the system and its users or other systems [18]. They are crucial for describing the functionalities of the system, aiding in understanding the options provided for stakeholders and maintainers of the software. The use case diagram, a Unified Modeling Language (UML) artifact, uses actors, use cases, and relationships to visually communicate the software's scope. Actors are represented as stick figures, use cases as ellipses with their names inside, and relationships as lines connecting actors and use cases, determining who is responsible for each functionality. To enhance the understanding of the application's flow, a use case diagram was created based on scenario-driven techniques. Figure 2 illustrates the overall use case diagram of the system.

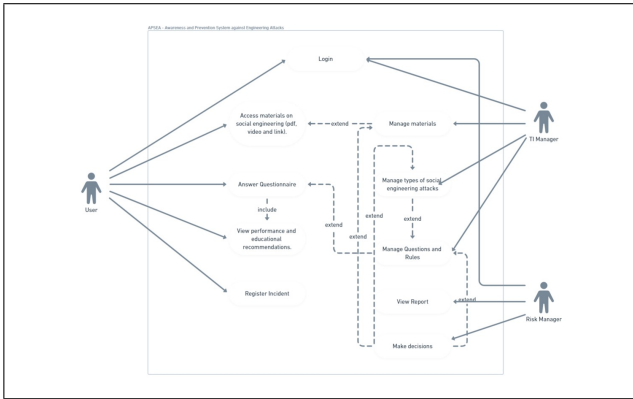


Fig. 2 Use Case Diagram

4.9 APSEA Architecture

The APSEA consists of three interconnected modules, each playing a specific role in raising awareness and preventing social engineering attacks. The overall architecture framework is as follows:

1. **IT Manager Module:** This module plays a critical role in managing the system's knowledge base. It enables IT managers to handle information relevant to the system, including data on social engineering threats, attack techniques, questions, and rules.
2. **User Module:** Designed for knowledge acquisition, this module interacts directly with end users. Its primary function is to provide information, materials, incident logging, and questionnaires related to social engineering. During the question sessions, the *Forward Chaining* method is applied, thereby increasing users' awareness of information security risks and how to prevent social engineering attacks. Additionally, users can track their progress within the system.
3. **Risk Manager Module:** This module is responsible for applying the *Forward Chaining* inference method based on user interactions and data provided by the IT Manager. From these interactions, the Risk Manager Module generates reports that allow the manager to diagnose vulnerabilities and identify specific areas for improvement within the organization. This is achieved through the use of artificial intelligence techniques, allowing APSEA to provide guidance for mitigating the identified issues.

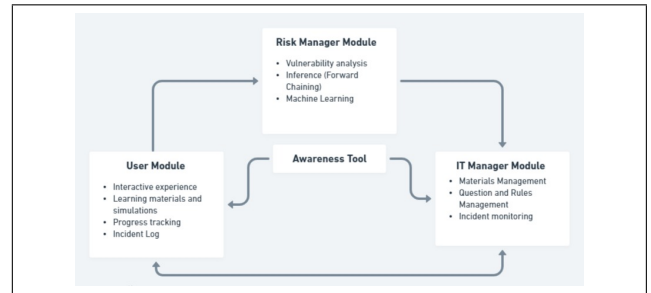


Fig. 3 APSEA architecture

To visualize the interaction between the modules and how the tool addressed awareness and prevention of social engineering attacks in public organizations, see Figure 3.

When a user interacts with APSEA, they have the option to access informational materials, log incidents, as well as perform one of the key actions, which is responding to the proposed questionnaire. While answering the questionnaire, the Forward Chaining analyzes

their responses. If a sequence of interactions indicates a potential social engineering attack scenario, the system can take preventive measures or alert the user about the potential threat. In this way, Forward Chaining enables faster and proactive detection of attempts at psychological manipulation and malicious attacks. After completing the questionnaire, the system provides feedback and recommendations to the user, aiming to increase awareness of potential risks and enhance overall security.

The integration of these three modules creates a robust framework that enables APSEA to educate, raise awareness, and provide solutions for the prevention of social engineering attacks.

4.10 APSEA Functionalities

The functionalities have been transformed into a comprehensive list of activities for each module, forming a detailed overview of APSEA's functionalities. The following provides an in-depth exploration of the specific operations offered within each component of the system.

1. IT Manager Module:

- The system should allow the IT manager to manage types of attacks social engineering by registering, editing, and deleting records.
- The system should allow the IT manager to manage materials by registering, editing, and deleting records.
- The system should allow the IT manager to manage questions and rules by registering, editing, and deleting records.
- The system should allow the IT manager to query incidents recorded by users.
- The system should allow the IT manager to analyze user assessments.

2. User Module

- The system must enable the user to access available materials.
- The system must allow the user to perform evaluations, learning from questions and feedback, and assessing the vulnerability level.
- The system must provide the user with the ability to view the performance of assessments and receive recommendations on how to avoid types of attacks.
- The system must facilitate the logging of incidents by the user and provide necessary instructions if needed.

3. Risk Manager Module

- The system should provide a feature to view detailed assessment reports of users.

- The system must facilitate the diagnosis of vulnerabilities and identification of specific areas for improvement based on user assessments.
- The system must provide data for the Risk Manager to decide on suitable mitigation strategies.

5 Implementation

In this section, we describe in detail the implementation of the Social Engineering Attack Prevention Environment (APSEA), presenting the crucial steps and highlighting key aspects of the system.

5.1 Technologies Used

The development of APSEA was conducted using a careful selection of technologies to ensure efficiency and robustness. The development environment was established in Visual Studio Code, a versatile source code editor. Furthermore, to simulate the behavior of a server, we use WampServer, incorporating Apache, MySQL and PHP. Laravel, a PHP framework based on the Model-View-Controller (MVC) pattern, was chosen to provide an organized and agile structure for development.

5.2 Prototypes

Before full implementation, we prototyped the system screens. These prototypes, although not interactive at the back-end level, allowed an initial understanding of the APSEA structure and the identification of future development needs.

5.3 CRUD of Records

The implementation of Create, Read, Update, Delete (CRUD) followed Laravel's MVC architecture. This approach facilitates efficient management of table records, covering attack types, materials, questions and rules, users, incident queries, and assessment analyses.

5.4 Validations

We emphasize the importance of validations to ensure the integrity of the data entered into the system. Laravel provides standard classes that are applied to validate HTTP requests, maintaining the accuracy of information essential for information security awareness.

5.5 Module Functions

We highlight the implementation of the functionalities previously outlined for each module during implementation:

- **IT Manager Module:** Allows the registration of materials, types of social engineering attacks, questions and rules, as well as querying incidents and analyzing assessments.
- **User Module:** Provides access to instructional materials, assessments, incident logging, and personalized recommendations.
- **Risk Manager Module:** It is dedicated to consulting detailed evaluation reports and making strategic decisions based on these reports.

This section provides a comprehensive view of the implementation of APSEA, highlighting its functionalities and the technological base that supports its operations. The system represents a proactive approach to preventing social engineering attacks, strengthening awareness and information security in the organization.

6 Qualitative and performance assessment

In this section, we perform a qualitative evaluation to validate the effectiveness of APSEA (*Awareness and Prevention Expert System against Social Engineering Attacks*). The qualitative approach provides deep and illustrative insights into the practical application of the system, focusing on the dynamic understanding of social relationships [19].

6.1 Study Location

The research took place in 2023 at the Sergipe State Traffic Department (DETRAN/SE), with an emphasis on the General Information and Communication Technology Advisory (AGIN). DETRAN/SE, a state authority, plays a crucial role in implementing traffic and safety policies.

AGIN, the central location of the study, stands out for its work in protecting sensitive information, adopting advanced cybersecurity practices. The assessment was carried out directly in AGIN operations, ensuring the validity of the actions implemented against social engineering attacks.

6.2 APSEA Performance Level Assessment

The APSEA assessment included a testing phase, together with the completion of the Performance Level

Assessment Questionnaire *Likert*. Participants, representing the AGIN team, were guided to explore and test APSEA, contributing to a comprehensive assessment of its attributes.

Assessment attributes such as Functional Suitability, Reliability, Usability, Performance Level, Compatibility and Security were carefully considered. We use a *Likert* scale aligned with ISO/IEC 25010, allowing a thorough assessment of user satisfaction.

The satisfaction scale ranges from 1 (Not Appropriate) to 5 (Completely Appropriate), as defined by the ISO/IEC 25010 guidelines (*System and Software Engineering - System and Software Quality Requirements and Evaluation - SQaRE - System and Software Quality Models*) [20].

ISO/IEC 25040 (*System and Software Engineering - SQaRE - Evaluation Process*) is an international standard that establishes a set of 8 characteristics aimed at evaluating *software*, each characteristic is composed of subcharacteristics, totaling 31 subcharacteristics, related to the properties to be measured and evaluated to establish the quality of the *software* product (ISO/IEC, 2011)

The Table 1 below summarizes the *Likert* scale, offering the 15 participants a clear basis for expressing their satisfaction in relation to each evaluated attribute:

The questionnaire was designed to assess participants' perceptions and satisfaction regarding various attributes of the APSEA (*Awareness and Prevention Expert System against Engineering Attacks*) tool. The participants, representing the AGIN team, were actively engaged in exploring and testing the functionalities of APSEA.

The evaluation of APSEA in the controlled environment provided a detailed understanding of its effectiveness, guided by active participation and feedback from users. The following section discusses the results and implications of the assessment, highlighting the impact of APSEA on awareness and prevention against social engineering attacks.

7 Results

From November to December 2023, we conducted tests on the APSEA system with 15 IT professionals from DETRAN/SE. The participants included various roles, such as analysts, developers, and managers. The overall assessment of APSEA's performance, as shown in Figure 4, reveals positive feedback across various attributes.

The evaluation of the developed APSEA in this study involved calculating the average scores assigned by participants for each attribute. The overall mean ratings

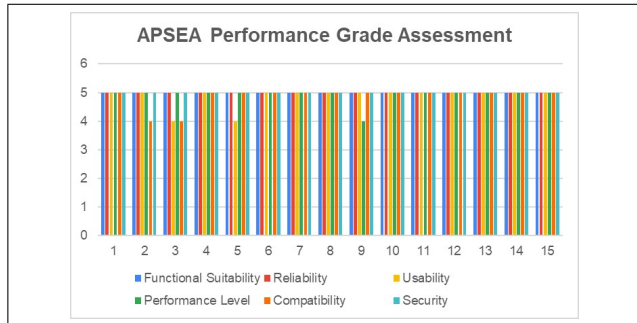
Table 1 Likert Scale to assess user satisfaction level.

Scale Item	Definition	Score
Not Appropriate	Not adapted, does not correspond in any way to the proposed objective.	1
Not very Appropriate	Corresponds very little to the proposed objective.	2
Moderately Appropriate	Moderately corresponds to the proposed objective.	3
Very Appropriate	Intensely corresponds to the proposed objective.	4
Completely Appropriate	Perfectly corresponds to the proposed objective.	5

Source: Adapted from [20]

Table 2 Questions in the Likert Scale Questionnaire

Likert Scale Questions
1. Does the software functionality meet what was proposed?
2. How reliable is the system in performing the necessary functions?
3. How much effort is required to use APSEA?
4. What is the APSEA Performance Level?
5. What is the ability to maintain the level of performance over a period of time?
6. What is the Protection of information and data and Level of access for people?

**Fig. 4** Overall Assessment of APSEA's Performance

for each attribute were as follows: Functional Adequacy (Adequação Funcional) 5.0 (100%), Reliability (Confiabilidade) 5.0 (100%), Usability (Usabilidade) 4.8 (96%), Performance Level (Nível de Desempenho) 4.9 (98%), Compatibility (Compatibilidade) 4.8 (96%), and Security (Segurança) 5.0 (100%). These high scores indicate the system's effectiveness in meeting user expectations and requirements.

Specifically, in terms of Functional Adequacy, it is observed that 100% of the evaluators rated the system as 'Completely Appropriate,' resulting in a percentage average of 100%. This assessment confirms that the tool fully meets the proposed requirements, highlighting its effective functionality.

Similarly, the analysis of Reliability reveals that 100% of the assessments indicated 'Completely Appropriate' levels. The percentage average for this attribute also reached 100%, indicating the professionals' confidence in the APSEA's ability to execute its functions reliably.

Usability of the APSEA achieved a percentage average of 86.67%, where the majority of participants (86.67%) considered the system 'Completely Appropriate,' while 13.33% opted for 'Very Appropriate.' This evaluation underscores the efficiency of the APSEA, making its use accessible and minimizing efforts on the part of users.

When evaluating Performance Level, 93.33% of the evaluators rated the APSEA as 'Completely Appropriate,' while 6.67% opted for 'Very Appropriate.' The assessment highlights the system's effectiveness in achieving high performance, meeting user expectations satisfactorily.

In terms of Compatibility, all evaluations, totaling 100%, indicated 'Very or Completely Appropriate' levels. This assessment emphasizes the excellent ability of the APSEA to maintain its performance over time.

Finally, the Security of the APSEA was rated as 'Completely Appropriate' by 100% of the participants, resulting in a percentage average of 100%. This confirms that the data protection and information security

measures of the APSEA are adequate and meet the intended objectives.

Notably, 14 out of 15 participants had no suggestions for improvement, expressing satisfaction. However, one participant suggested enhancing user experience by incorporating more illustrative and playful information about Social Engineering attacks. This proposal aims to make learning more engaging and visually appealing.

In conclusion, the evaluations affirm the success of APSEA in addressing Social Engineering threats, demonstrating high performance and user satisfaction.

8 Conclusion

The results of the evaluation of our expert system (APSEA) aimed at awareness and prevention against social engineering attacks demonstrate that the approach adopted is effective in achieving its objectives. The system was developed to offer interactive training capabilities, presentation of educational content and assessment of user awareness.

Through interactive exercises and quizzes, users have the opportunity to learn about the risks associated with social engineering, the tactics used by attackers, and best practices for preventing these attacks. The ability to customize educational content and quizzes allows the IT Manager to adapt the system to the organization's specific needs.

Analyzing user responses and applying the forward chaining method allows the identification of specific vulnerabilities. The system generates detailed reports that highlight areas where users demonstrate a lack of awareness or poor security practices. These reports are made available to the Risk Manager, enabling corrective measures to be taken and continuous improvement of information security awareness.

Using APSEA promotes information security and prevents social engineering attacks. It prepares users to recognize and respond effectively to threats, reducing the risk of exposure to attacks and mitigating severe impacts on sensitive data.

Through this system, information security awareness is improved, users are trained and vulnerabilities are identified, promoting a safer environment for organizations.

Suggestions for future work include the expansion of APSEA to mobile platforms, such as Android and iOS, to enhance accessibility and reach a broader audience. Additionally, exploring the integration of complementary AI resources, such as Machine Learning and Neural Networks, could further enrich APSEA's capabilities,

offering a more comprehensive solution for awareness and prevention against social engineering attacks.

While the study provides valuable insights, it is essential to acknowledge certain threats to validity. The limited sample size of 15 participants within the Information Technology sector, while necessary due to logistical constraints, may impact the generalizability of results. Future studies should consider expanding the sample to include a more diverse participant pool, encompassing various sectors and public entities, for a more comprehensive understanding.

The study's bias towards the technology sector might limit the direct applicability of conclusions to other industries. Additionally, resource constraints, including time and participants' availability, pose challenges to the study's depth and quality. Acknowledging these limitations is crucial for interpreting and applying the results effectively.

In future research, addressing these validity threats and considering a more extensive and diverse participant pool will contribute to a more robust understanding of the effectiveness and applicability of APSEA across different organizational contexts.

Acknowledgements We, the authors of this paper, would like to express our gratitude to our supervisor for their assistance in completing this research. And we would like to thank our university, the Federal University of Sergipe, Brazil, for their support

Author contributions Author WRC wrote the main manuscript and all its components. Additionally, he was responsible for the design, development and implementation, including conducting the quality and performance assessment of the APSEA tool described in the manuscript. Authors ARLR and JMCS supervised the work, performed reviews, and provided suggestions for further improvement in design and implementation. Both authors actively collaborated in conducting the qualitative and performance evaluation of APSEA. In summary, the contributions of ARLR and JMCS were essential for the conception, implementation, and successful evaluation of APSEA. Their dedication and combined expertise significantly enriched the field of information security, providing an innovative solution for awareness and prevention against social engineering attacks in public organizations.

Funding Not applicable.

Data availability Data sharing not applicable to this article as no datasets were generated or analyzed during the current study.

Declarations

Competing Interests The authors declare that they have no known competing financial interests or personal relation-

ships that could have appeared to influence the work reported in this paper.

Human or animal rights This article does not contain any studies involving animals performed by any of the authors.

Informed consent Informed consent was obtained from all individual participants involved in the study. Identity of participants in the experiment described in the article is kept anonymous for privacy purposes.

References

1. T. Grassegger and D. Nedbal, "The Role of Employees' Information Security Awareness on the Intention to Resist Social Engineering," *Procedia Computer Science*, vol. 181, pp. 59-66, 2021. doi: 10.1016/j.procs.2021.01.103
2. A. Kamruzzaman, K. Thakur, S. Ismat, M. L. Ali, K. Huang, and H. N. Thakur, "Social engineering incidents and preventions," in *2023 IEEE 13th Annual Computing and Communication Workshop and Conference (CCWC)*, 2023, pp. 494-498.
3. K. Krombholz et al., "Advanced social engineering attacks," *Journal of Information Security and Applications*, vol. 22, pp. 113-122, 2015. ISSN 2214-2126. Special Issue on Security of Information and Networks.
4. M. R. Arabia-Obedoza, G. Rodriguez, A. Johnston, F. Salahdine, and N. Kaabouch, "Social Engineering Attacks: A Reconnaissance Synthesis Analysis," in 2020 11th IEEE Annual Ubiquitous Computing, Electronics & Mobile Communication Conference (UEMCON), New York, NY, USA, 2020, pp. 843-848, doi: 10.1109/UEMCON51285.2020.9298100.
5. E. S. Mandrakov, V. A. Vasiliev, and D. A. Dudina, "Application of expert systems in quality management," in 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies, [S.l.], 2021, pp. 516-518.
6. S. W. Sihwi, F. Andriyanto, and R. Anggrainingsih, "An expert system for risk assessment of information system security based on ISO 27002," in *2016 IEEE International Conference on Knowledge Engineering and Applications (ICKEA)*, 2016, pp. 56-61.
7. J. Yu, P. Tian, H. Feng, and Y. Xiao, "Research and design of subway based intrusion detection expert system," in *2018 IEEE 3rd Advanced Information Technology, Electronic and Automation Control Conference (IAEAC)*, 2018, pp. 152-156.
8. C. Rani and S. Goel, "CSAAES: An expert system for cyber security attack awareness," in *International Conference on Computing, Communication Automation*, 2015, pp. 242-245.
9. E. U. Osuagwu, G. A. Chukwudebe, T. Salihu, and V. N. Chukwudebe, "Mitigating social engineering for improved cybersecurity," in *2015 International Conference on Cyberspace (CYBER-Abuja)*, 2015, pp. 91-100.
10. A. Khlobystova and M. Abramov, "Time-based model of the success of a malefactor's multistep social engineering attack on a user," in *SPRINGER International Conference on Intelligent Information Technologies for Industry*, [S.l.], 2021, pp. 216-223.
11. R. A. Hammour et al., "The status of information security systems in banking sector from social engineering perspective," in *Proceedings of the Second International Conference on Data Science, E-Learning and Information Systems (DATA '19)*, New York, NY, USA, 2019, ISBN 9781450372848, pp. N/A. doi: 10.1145/3368691.3368705.
12. P. Jansen and F. Fischbach, "The social engineer: An immersive virtual reality educational game to raise social engineering awareness," in *Extended Abstracts of the 2020 Annual Symposium on Computer-Human Interaction in Play (CHIPLAY '20)*, New York, NY, USA, Association for Computing Machinery, 2020, pp. 59-63, ISBN 9781450375870, doi: 10.1145/3383668.3419917.
13. N. Sohrabi Safa, R. Von Solms, and S. Furnell, "Information security policy compliance model in organizations," in *Computers & Security*, vol. 56, pp. 70-82, 2016, ISSN 0167-4048, doi: 10.1016/j.cose.2015.09.006.
14. L. Astakhova and I. Medvedev, "Scanning the resilience of an organization employees to social engineering attacks using machine learning technologies," in 2020 Ural Symposium on Biomedical Engineering, Radioelectronics and Information Technology (USBREIT), [S.l.], 2020, pp. 606-610, doi: 10.1109/USBREIT51578.2020.9256762.
15. E. T. V. de Castro, G. R. S. Silva, and E. D. Canedo, "Ensuring Privacy in the Application of the Brazilian General Data Protection Law (LGPD)," in *Proceedings of the 37th ACM/SIGAPP Symposium on Applied Computing*, pp. 1228-1235, Virtual Event, 2022.
16. M. M. G. Ferreira, T. N. de Azevedo, T. Y. Eguchi, S. N. Ferreira Junior, and R. G. da Silva, "Aplicação do Software Expert Sinta objetivando o auxílio da tomada de decisão em situação de acidente de trabalho em uma madeireira," *Brazilian Journal of Development*, vol. 6, no. 3, pp. 14704-14715, 2020.
17. J. Yanase and E. Triantaphyllou, "A systematic survey of computer-aided diagnosis in medicine: Past and present developments," *Expert Systems with Applications*, vol. 138, pp. 112821, 2019.
18. Ian Sommerville, *Software Engineering*, 8th edition. Pearson Addison Wesley, São Paulo, 2007. ISBN: 9788588639287.
19. Denise Tolfo Silveira and Fernanda Peixoto Córdova, "Scientific Research," in *Research Methods*. Porto Alegre: Editora da UFRGS, 2009, pp. 33-44.
20. G. F. Felipe, F. E. T. Lima, L. P. Barbosa, T. M. M. Moreira, E. S. Joventino, V. S. Freire, L. B. A. Mendonça, "Evaluation of software for triage with risk classification in pediatrics," *Brazilian Nursing Magazine*, vol. 73, 2020. SciELO Brazil.